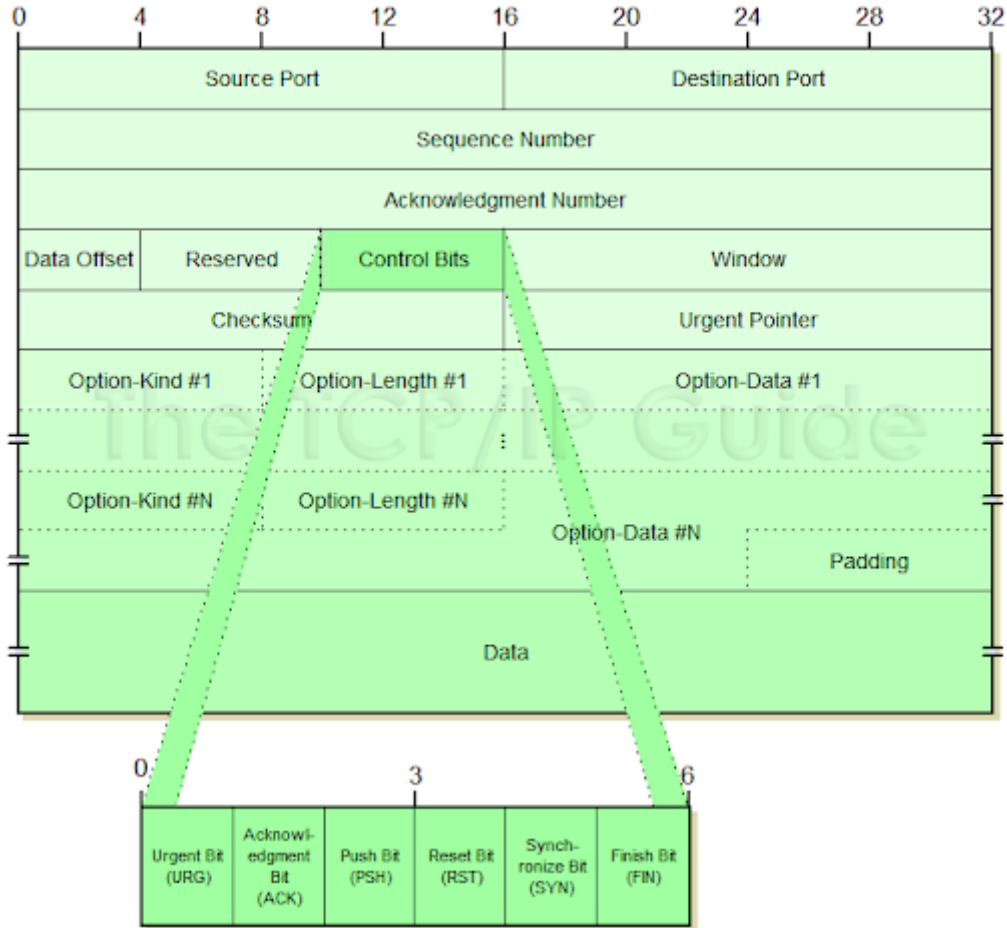


TCP ve UDP Güvenlik Açıkları

TCP Segment Header (TCP Segment Başlığı)

- TCP bölüm bilgileri IP üstbilgisinden hemen sonra görünür. TCP segmentinin alanları ve kontrol bitleri alanının bayrakları şekilde gösterilmiştir.
- TCP segmentinin altı kontrol biti aşağıdadır:
- **URG** – Urgent pointer field significant (Acil İşrateçi Alanı)
- **ACK** – Acknowledgement field significant (Teşekkür/Kabul alanı)
- **PSH** – Push function (İtme işlevi)
- **RST** – Reset the Connection (Bağlantıyı sıfırla)
- **SYN** – Synchronize sequence numbers (Sıra numaralarını senkronize etme)
- **FIN** – No more data from sender (Gönderenden başka veri yok)



TCP Servisleri

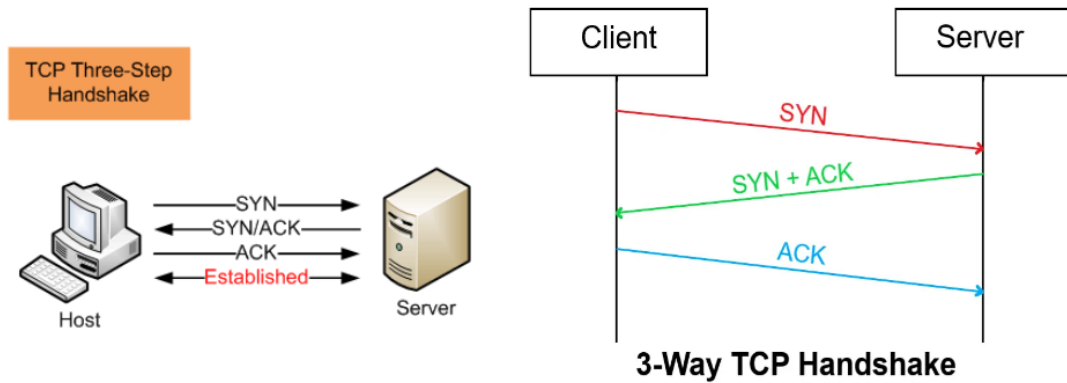
TCP şu hizmetleri sağlar:

- **Reliable Delivery (Güvenilir Teslimat):** TCP, teslimatı garanti etmek için onayları içerir. Zamanında onay alınmazsa, gönderen verileri yeniden iletir. Alınan verilerin onaylanmasını istemek önemli gecikmelere neden olabilir. TCP güvenilirliğini kullanan uygulama katmanı protokollerine örnek olarak http, SSL/TLS, FTP, DNS bölge aktarımları ve diğerleri verilebilir.
- **Flow Control (Akış Kontrolü):** TCP, bu sorunu gidermek için akış kontrolü uygular. Bir kerede bir segmenti kabul etmek yerine, tek bir alındı birimi ile birden fazla segment kabul edilebilir.
- **Stateful Communication (Durum Bilgisi Olan İletişim):** İki taraf arasında TCP durum bilgisi olan iletişim, TCP'nin üç yönlü el sıkışması sırasında gerçekleşir.

Üç adımda bir TCP bağlantısı kurulur:

- 1) Başlatılan istemci, sunucuyla bir istemciden sunucuya iletişim oturumu ister.
- 2) Sunucu, istemciden sunucuya iletişim oturumunu onaylar ve sunucudan istemciye iletişim oturumu ister.
- 3) Başlatılan istemci, sunucudan istemciye iletişim oturumunu onaylar.

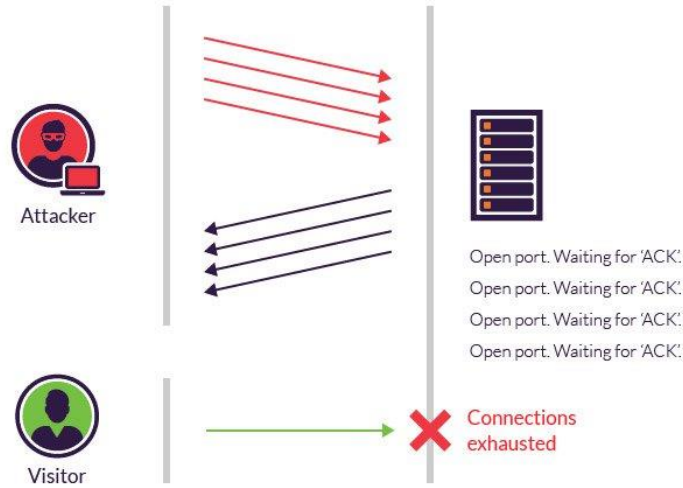
3 Way TCP handshake to establish a TCP Connection



TCP Saldırıları

TCP SYN Flood Attack (TCP SYN Sel Saldırısı)

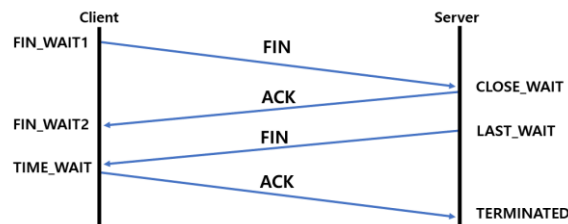
1. Tehdit aktörü bir web sunucusuna birden fazla SYN isteği gönderir.
2. Web sunucusu, her SYN isteği için SYN-ACK'larla yanıt verir ve üç yollu el sıkışmasını tamamlamayı bekler. Tehdit aktörü SYN-ACK'lara yanıt vermez.
3. Geçerli bir kullanıcı, web sunucusunda yarı açık çok fazla TCP bağlantısı bulunduğu için web sunucusuna erişemez.



TCP oturumunu sonlandırmak için aşağıdaki dört yönlü değişim işlemi kullanılır:

1. İstemcinin akışta gönderecek başka veri yoksa, FIN bayrağı ayarlanmış bir segment gönderir.
2. Sunucu, oturumu istemciden sunucuya sonlandırmak için FIN'nin alındığını onaylamak için bir ACK gönderir.
3. Sunucu, sunucudan istemciye oturumu sonlandırmak için istemciye bir FIN gönderir.
4. İstemci bir ACK ile yanıt verir ve sunucudan FIN'yi onaylar.

Bir tehdit aktörü TCP sıfırlama saldırısı yapabilir ve bir TCP RST içeren sahte bir paket gönderebilir.



TCP oturumu ele geçirme başka bir TCP güvenlik açığıdır. Yürütülmesi zor olsa da, bir tehdit aktörü, hedefle iletişim kurarken zaten kimliği doğrulanmış bir ana bilgisayarı devralır. Tehdit aktörü bir ana bilgisayarın IP adresini aldatmalı, sonraki sıra numarasını tahmin etmeli ve diğer ana bilgisayar bir ACK göndermelidir. Başarılı olursa, tehdit aktörü hedef cihazdan veri gönderebilir, ancak alamaz.

UDP Segment Header and Operation (UDP Segment Başlığı ve İşlemi)

- UDP (User Datagram Protocol) yaygın olarak DNS, TFTP, NFS ve SNMP tarafından kullanılır. Medya akışı veya VoIP gibi gerçek zamanlı uygulamalarla da kullanılır. UDP bağlantısız bir taşıma katmanı protokolüdür. TCP'ye göre çok daha düşük ek yüke sahiptir, çünkü bağlantı odaklı değildir ve güvenilirlik sağlayan gelişmiş yeniden iletim, sıralama ve akış kontrol mekanizmaları sunmaz.
- Bu güvenilirlik işlevleri, taşıma katmanı protokolü tarafından sağlanmaz ve gerekirse başka bir yerde uygulanmalıdır.
- UDP'nin düşük ek yükü, basit talep ve yanıt işlemleri yapan protokoller için çok arzu edilir kılımdır.

TCP Segment Header Format								
Bit #	0	7	8	15	16	23	24	31
0	Source Port				Destination Port			
32	Sequence Number							
64	Acknowledgment Number							
96	Data Offset	Res	Flags			Window Size		
128	Header and Data Checksum				Urgent Pointer			
160...	Options							

UDP Datagram Header Format									
Bit #	0	7	8	15	16	23	24	31	
0	Source Port				Destination Port				
32	Length				Header and Data Checksum				

UDP Saldırıları

- UDP herhangi bir şifreleme ile korunmaz. UDP'ye şifreleme ekleyebilirsiniz, ancak varsayılan olarak kullanılmaz. Şifrelemenin olmaması, herkesin trafiği görebileceği, değiştirebileceği ve hedefine gönderebileceği anlamına gelir.
- UDP Flood Attacks (UDP Sel Saldırıları): Tehdit aktörü UDP Unicorn veya Low Orbit Ion Cannon gibi bir araç kullanır. Bu araçlar, genellikle sahte bir ana bilgisayardan alt ağdaki bir sunucuya bir UDP paketi seli gönderir. Program, kapalı portları bulmaya çalışan bilinen tüm portları tarayacaktır. Bu, sunucunun ICMP bağlantı noktasına erişilemiyor olmasıyla yanıt vermesine neden olur. Sunucuda çok sayıda kapalı bağlantı noktası bulunduğundan, bu, segmentte bant genişliğinin çoğunu kullanan çok fazla trafik oluşturur. Sonuç bir DoS saldırısına çok benzer